Hardware Trojans em HQC

Mapeamento de superfícies críticas, hipóteses verificáveis e prioridades para experimentos em RTL

Escopo: análise de ameaças a implementações digitais do Hamming Quasi-Cyclic (HQC), com foco em confidencialidade, integridade e disponibilidade. Hipóteses de Trojan não devem ser confundidas com ataques efetivamente demonstrados na implementação fornecida.

Nota temporal importante: a especificação HQC de 12/10/2026 atualizou os parâmetros, o formato de chave e o polinômio de GF(2^8). O arquivo RTL fornecido é de uma arquitetura anterior e não foi comprovado equivalente ao texto normativo atual [1].

Síntese executiva

Os módulos potencialmente mais relevantes não se limitam à memória de chave: lógica de verificação na decapsulação, amostragem de vetores de peso fixo, multiplicação polinomial, decodificadores Reed–Muller / Reed–Solomon e controladores FSM expõem propriedades de segurança diferentes. Um Trojan pode preservar respostas funcionais comuns e ainda violar uma propriedade estatística, de temporalidade ou de fluxo de controle.

Prioridade	Módulo	Propriedade exposta
1 — crítica	Verificação FO / comparadores	Validação do ciphertext e seleção da saída correta
2 — crítica	Sampler de peso fixo	Uniformidade, independência e peso de Hamming
3 — alta	Multiplicador polinomial	Integridade de operandos secretos e resultados
4 — alta	Decodificadores RM / RS	Integridade de mensagem, flags e estados internos
5 — alta	SHAKE / interface de hash	Derivação e isolamento de contextos
6 — alta	FSM / handshakes	Sequenciamento e conclusão de operações
7 — média-alta	Registradores / BRAM	Isolamento, persistência e limpeza de dados
8 — exploratória	Clocks / CDC	Integridade temporal e liveness

1. Arquitetura HQC: onde os dados circulam

Um acelerador HQC envolve KeyGen, Encaps e Decaps. Seus componentes típicos incluem SHAKE/Keccak, sampler de peso fixo, aritmética binária de polinômios, codificação e decodificação concatenadas Reed–Muller/Reed–Solomon, memórias e FSMs. Uma implementação documentada compartilha SHAKE256 entre as etapas e admite múltiplos domínios de clock [3,4]. A topologia varia entre projetos.

Fluxo conceitual da decapsulação: ciphertext recebido → combinação com dados privados → decodificação RM/RS → mensagem candidata → recifragem / comparações → derivação do segredo ou caminho de rejeição. Essa sequência é uma visão funcional; não substitui a análise dos sinais do RTL

escolhido.

2. Verificação FO e fluxo da decapsulação

No KEM, a verificação da consistência do ciphertext por recifragem é propriedade de segurança essencial. Operações corretas Encaps→Decaps com entradas válidas não exercitam suficientemente o caminho de falha. Um trabalho da CRYPTO 2025 demonstrou que omissões na verificação podem escapar de testes convencionais, mencionando um defeito histórico de referência HQC que permaneceu despercebido por 19 meses [7].

- **Hipóteses:** sinal de comparação incorreto, fim prematuro, caminho indevido de seleção do segredo, verificações não consumidas pela FSM.
- **Testes:** ciphertext válido; ciphertext corrompido; checagem da divergência; asserts de que o caminho apropriado foi concluído antes de `done`.
- **Limite:** as verificações FO da versão 2026 não devem ser presumidas idênticas às de uma arquitetura 2022/2023 [1].

3. Sampler de vetores de peso fixo

A correção não depende somente de gerar vetores com Hamming weight esperado. A distribuição e a independência das posições também são relevantes. Uma versão enviesada pode preservar o peso e escapar de um teste que verifica apenas popcount. Estudos de timing sobre rejection sampling em HQC e BIKE reforçam o interesse nessa superfície [9].

- **Hipóteses:** viés de escolha, repetições entre sementes, tratamento errado de colisões, anomalia temporal na seleção de índices.
- **Testes:** frequências de cada índice, uniformidade, correlação entre saídas, contagem de colisões e invariantes de peso para amostras independentes.

4. Multiplicação polinomial

O HQC utiliza operações binárias de polinômios com redução no anel. Multiplicadores são regiões densas de XOR, deslocamentos, buffers e controle; podem ser alterados para introduzir inconsistências raras. Um estudo de 2026 demonstrou ataque de análise de potência em uma implementação software específica, e não no módulo FPGA deste ZIP [10].

- **Hipóteses:** corrupção de produto parcial, acesso incorreto à memória de operandos e variações na latência correlacionadas a dados.
- **Testes:** referência matemática independente, comparação bit a bit, cobertura de carregamento/descarga e verificação temporal quando pertinente.

5. Decodificadores Reed–Muller e Reed–Solomon

O Reed–Muller emprega etapas de expansão/soma, transformada de Hadamard e seleção de picos. O Reed–Solomon opera sobre símbolos em um corpo finito e utiliza mecanismos de localização/correção de erros. Há demonstrações documentadas de canal lateral no Hadamard de RM e ataques single-trace em RS em plataformas específicas [5,6].

- **Hipóteses:** alteração de empate na seleção de picos, índice do erro, atualização de syndrome, sinalização de conclusão, supressão de escrita de byte decodificado.
- **Testes:** entradas de fronteira de correção; igualdade de magnitudes; contagem exata de resultados; correspondência entre `valid`, endereço e `done`.

6. SHAKE/Keccak, sementes e interfaces

Alterações na função hash e, principalmente, no mux que seleciona sementes, domínio e contexto de operação podem comprometer derivação e independência de chaves. Quando SHAKE é compartilhado entre KeyGen, Encaps e Decaps, as interfaces de controle se tornam superfícies de concentração [3,4].

- **Testes:** vetores conhecidos de hash, distinção de domínio, isolamento entre transações, reset e limpeza de estado temporário.

7. FSM, memória e clock domains

Trojans de controle podem produzir um resultado incorreto sem alterar a aritmética. Handshakes que desalinham `valid`, endereço e escrita; conclusão prematura; registradores não limpos; ou falhas de sincronização constituem classes separadas de problemas. Simulação RTL funcional não comprova metastabilidade física nem vazamento por consumo de energia.

- **Propriedade ilustrativa:** uma confirmação de finalização só ocorre se todas as gravações exigidas foram aceitas.
- **Propriedade ilustrativa:** após reset, nenhum registrador observável deve reter material da transação anterior se a arquitetura exigir apagamento.

8. Cenários experimentais propostos

ID	Superfície	Hipótese operacional	Verificação
HT-01	FO / FSM	Comparação ou seleção defeituosa	Entradas válidas/inválidas, assert temporal
HT-02	Sampler	Distribuição de índices alterada	Amostragem estatística e popcount
HT-03	GF / polinômios	Produto alterado em condição específica	Oracle matemático e regressão
HT-04	RM / RS	Pico ou byte decodificado inconsistente	Casos limite e monitor de gravação
HT-05	SHAKE	Contexto ou semente incorreta	Vetores de referência e rastros de controle
HT-06	Memória	Dados residuais entre operações	Reset, leitura, isolamento de contexto
HT-07	Temporal	Desvio na latência com mesma saída	Contagem de ciclos e atividade

9. Como transformar o estudo em resultado para IEEE

Organize pares **golden/variante** com um único defeito por experimento; registre hash e procedência dos arquivos; mantenha estímulos e seeds reproduzíveis; use testes unitários, testes fim a fim e invariantes; separe métricas da detecção por LLM das métricas da simulação RTL. Reporte falsos positivos, localização de sinais, categoria de payload, cobertura de ativação, impacto funcional e overhead, quando medido.

Para esta pesquisa, a prioridade prática inicial é uma combinação de três unidades delimitadas: multiplicação GF(2^8), controlador de saída da decodificação e seleção de picos RM. Esses casos testam, respectivamente, integridade de dados, integridade de controle e decisão em uma condição de fronteira. Não equivalem a uma demonstração de recuperação de segredo.

10. Limites científicos que devem constar no artigo

- Efeito num testbench não implica exploit criptográfico nem extração de chave.
- Passar em KATs não comprova ausência de Trojans ou correção de rejeição implícita.
- Uma diferença no tempo de simulação RTL não demonstra um canal lateral físico.
- Os mecanismos de ataques de software publicados não se transferem automaticamente a hardware dedicado.
- Qualquer benchmark deve declarar claramente a versão do HQC, do RTL e dos parâmetros.

Referências verificadas

[1] HQC: especificação oficial, revisão de 12/10/2026. Abrir fonte.

[2] NIST: seleção do HQC para padronização em 2025. Abrir fonte.

[3] Deshpande et al.: Fast and Efficient Hardware Implementation of HQC, SAC 2023 (repositório). Abrir fonte.

[4] Deshpande: A Fast Hardware Implementation of HQC, NIST PQC Conference 2022. Abrir fonte.

[5] Goy, Loiseau e Gaborit: A New Key Recovery Side-Channel Attack on HQC with Chosen Ciphertext, 2022. Abrir fonte.

[6] Goy et al.: Single Trace HQC Shared Key Recovery with SASCA, NIST PQC Conference 2024. Abrir fonte.

[7] Glabush et al.: Verifiable Decapsulation, CRYPTO 2025. Abrir fonte.

[8] Schröder, Gast e Guo: Divide and Surrender, USENIX Security 2024. Abrir fonte.

[9] Guo et al.: Don't Reject This, IACR TCHES 2022. Abrir fonte.

[10] Simple Power Analysis of Polynomial Multiplication in HQC, ICISSP 2026. Abrir fonte.